

Bulk Email · HTML safety guard

Tresor Couture · automated end-to-end test report

Area	Admin console · Bulk Email
Test id	bulk-email-html-safety
Result	PASSED
Duration	0.0s
Executed	2026-08-10T09:01:13.677Z
Environment	Firebase Emulator Suite (Auth + Firestore) loading the production firestore.rules

WHAT THIS VERIFIES

The bulk-email composer relays admin-authored HTML to customer inboxes. The server refuses HTML containing script tags, javascript: URLs, inline event handlers, iframes, objects or embeds — so a compromised admin session cannot turn the mailing list into a phishing vector — while leaving ordinary marketing HTML untouched.

REPRODUCE MANUALLY

1. Sign in as an admin and open `#/admin/bulk-email`.
2. Compose a campaign whose HTML body contains a `<script>` tag, or a link with a `javascript: URL`.
3. Attempt to send: the request is rejected with `html_content_forbidden` and nothing is dispatched.
4. Replace it with ordinary marketing HTML (headings, links, images, tables): the content is accepted.
5. The same rule is unit-exercised by this test against nine attack payloads and three legitimate ones.

STEPS (13)

1 ✓ Blocked: script tag

Rejected as `html_content_forbidden`.

No screenshot — data assertion.

2 ✓ Blocked: uppercase script tag

Rejected as `html_content_forbidden`.

No screenshot — data assertion.

3 ✓ Blocked: javascript: URL

Rejected as `html_content_forbidden`.

No screenshot — data assertion.

4 ✓ Blocked: inline onclick handler

Rejected as `html_content_forbidden`.

No screenshot — data assertion.

5 ✓ **Blocked: onerror on a broken image**

Rejected as html_content_forbidden.

No screenshot — data assertion.

6 ✓ **Blocked: onload handler**

Rejected as html_content_forbidden.

No screenshot — data assertion.

7 ✓ **Blocked: iframe**

Rejected as html_content_forbidden.

No screenshot — data assertion.

8 ✓ **Blocked: object embed**

Rejected as html_content_forbidden.

No screenshot — data assertion.

9 ✓ **Blocked: embed tag**

Rejected as html_content_forbidden.

No screenshot — data assertion.

10 ✓ **Allowed: plain marketing copy**

Ordinary marketing HTML passes untouched.

No screenshot — data assertion.

11 ✓ **Allowed: styled layout with a link**

Ordinary marketing HTML passes untouched.

No screenshot — data assertion.

12 ✓ **Allowed: image and table**

Ordinary marketing HTML passes untouched.

No screenshot — data assertion.

13 ✓ **Empty body rejected as html_content_required**

Distinguished from forbidden content so the admin sees the right message.

No screenshot — data assertion.